แบบจำลองการเจาะระบบเว็บพนันเพื่อเปลี่ยนกลไกระบบ

รหัสโครางงาน (1101203)

จัดทำโดย

นายรชต	เทียมโคกกรวด	รหัสนักศึกษา	B6601164
นางสาวลภัสรดา	ลืออดุลย์	รหัสนักศึกษา	B6601591
นายกิตติพิชญ์	วงษ์วรรณ	รหัสนักศึกษา	B6602789
นายวันชนะ	สุวรรณพันธ์	รหัสนักศึกษา	B6701505
นายนพรัตน์	แพ่งแสง	รหัสนักศึกษา	B6701512
นายปัณณทัต	มีลาภ	รหัสนักศึกษา	B6702632
นายจิณณพัฒน์	บุญแพง	รหัสนักศึกษา	B6703158
นายพนิตนันท์	สิงห์วงศ์	รหัสนักศึกษา	B6703189

อาจารย์ที่ปรึกษาโครงงาน

รองศาสตราจารย์ ดร. ศิรปัฐช์ บุญครอง

รายงานนี้เป็นส่วนหนึ่งของรายวิชา 101203 โครงงานความมั่นคงปลอดภัยทางไซเบอร์

1.ที่มาและความสำคัญของปัญหา

จากข้อมูลทางสถิติจากสำนักงานเฮ็ชโพกัส พบว่าในปีพุทธศักราช 2566 – 2567 นั้น มีเด็ก เยาวชน ผู้สูงอายุ ที่เข้าใช้เว็บพนันในประเทศไทย ดังแสดงในตารางที่ 1

ตารางที่ 1 จำนวนผู้เข้าเล่นเว็บพนันในประเทศไทย ระหว่างปีพุทธศักราช 2566 – 2567

ช่วงวัย	**จำนวนผู้เข้าใช้เว็บพนัน**
เด็ก	1,060,000 คน
เยาวชน	3,920,000 คน
ผู้สูงอายุ	4,470,000 คน

จำนวนผู้เข้าใช้เว็บพนันในตารางที่ 1 ทำให้เห็นว่า ในปีพุทธศักราชนั้น 2566 - 2567 มีผู้เข้าใช้เว็บพนันจำนวนมาก ไม่ว่าจะเป็น เด็ก เยาวชน หรือผู้สูงอายุ ต่างเข้าใช้เว็บพนันจำนวนมาก อย่างไรก็ตาม ประเด็นหนึ่งที่เป็นที่สนใจในสังคมก็คือ การที่เว็บพนันสามารถหลอกให้ผู้ใช้สามารถเชื่อได้ว่า การเล่นเว็บพนันทำให้มีความมั่งคั่งทางการเงินได้ โดยที่ผู้ใช้ไม่มีความรู้ความสามารถในการเข้าในกลไกของระบบเว็บพนันนั้นจริงๆ

เว็บพนันในประเทศไทยนั้นมีจำนวนมากจนสามารถดึงดูดผู้ที่สนใจในการเล่นพนันได้อย่างง่ายดาย เนื่องจากการเข้าถึงที่ง่ายเกินไปของเว็บพนัน การพนันที่เป็นยอดนิยมคือ การกพนันกีฬา เช่น ฟุตบอล ยังได้รับความนิยมสูงสุด (40-50% ของตลาดพนันออนไลน์ทั้งหมด) ส่วนการพนันประเภทอื่น ที่เรียกว่า “กาสิโอออนไลน์” เช่น บาคาร่า,รูเล็ต, และสล็อต ยังได้รับความนิยมสูงเช่นกันโดยเฉพาะเกมบาคาร่าและเกมสล็อตที่มีการโปรโมทผ่านโฆษณา
และโปรโมชั่นอย่างแพร่หลายในสื่อออนไลน์และโซเชียลมีเดียมีส่วนแบ่งในตลาดพนันออนไลน์ของประเทศไทยประมาณ 30-35%

ถึงแม้ว่าประเทศไทยมีกฎหมายที่ระบุไว้ชัดเจนว่า การเล่นพนันออนไลน์มีความผิดตามพระราชบัญญัติการพนัน พุทธศักราช 2478 เป็นกฎหมายหลักที่กำหนดให้ การพนันทุกประเภทเนื่องจากอาทิ การพนันกีฬา หวย แทงบอลออนไลน์ ฯลฯ ถือเป็นสิ่งผิดกฎหมาย ยกเว้นลอตเตอรี่ของรัฐและการเดิมพันแข่งม้าเท่านั้น กำหนดโทษสำหรับ การกระทำผิดเกี่ยวกับพนันออนไลน์ โดยระวางโทษ จำคุกไม่เกิน 10 ปี และปรับตั้งแต่ 20,000 ถึง 200,000 บาท หรือทั้งจำทั้งปรับ ก็ยังมีข่าวการเล่นพนันออนไลน์อยู่ เช่น วันที่ 11 ก.ค. 2568 พล.ต.ต.อธิป พงษ์ศิวาภัย ผบก.ปอท. สั่งการ พ.ต.อ.ชิษณุพงศ์ ไหวดี ผกก.3 บก.ปอท. พ.ต.ท.ชัยณรงค์ จอมเล็ก, พ.ต.ท.หญิง ภาพิมล ชัยขันธ์, พ.ต.ท.ประดิษฐ์ สุวรรณดี, พ.ต.ท.ณรงค์ฤทธิ์ พุ่มพวง, สว.กก.3 บก.ปอท. นำกำลังจับกุม นายจักรกฤษณ์ นวลฝ้าย อายุ 32 ปี, น.ส.สุธารินี บุตรทองทิม และนายโชคชัย ศิลา อายุ 31 ปี ในพื้นที่ อ.เมือง จ.อุบลราชธานี สืบเนื่องจากตำรวจ กก.3 บก.ปอท. สืบทราบว่า กลุ่มผู้ต้องหาร่วมกันเปิดเว็บไซต์พนันออนไลน์ ชื่อ VIPGAME66 จัดให้มีการเล่นพนันออนไลน์ต่างๆ เช่น สล็อต คาสิโน เป็นต้น จึงขออนุมัติศาลเข้าตรวจค้นจับกุม พร้อมตรวจยึดของกลาง รถยนต์ 2 คัน, คอมพิวเตอร์ 3 เครื่อง, โทรศัพท์มือถือ 5 เครื่อง, นาฬิกาข้อมือ 3 เรือน, หนังสือสัญญาจะซื้อจะขายที่ดิน

พร้อมบ้าน และบิลเงินสด 1 ชุด, สำเนาใบฝากเงินสด และสมุดบัญชีธนาคาร, อายัดเงินในบัญชีธนาคาร 2.8 ล้านบาท และอายัดเงินในบัญชีคริปโทเคอเรนซี่ 2 แสนบาท รวมทั้งหมด 17 รายการ มูลค่ารวม 4 ล้านบาท

การเล่นเว็บพนันออนไลน์ ไม่ได้เกิดขึ้นเฉพาะในประเทศไทยเท่านั้น ในต่างประเทศ เช่น ประเทศฟิลิปปินส์ ก็ยังมีข่าวเกี่ยวกับการจับกุมผู้ทำเว็บพนันเช่นกัน โดยในเดือนกุมภาพันธ์ 2568 ตำรวจฟิลิปปินส์ บุกเข้าทลายศูนย์

ปฏิบัติการเว็บพนันออนไลน์ผิดกฎหมายข้ามชาติ ที่มีชาวจีนเป็นเจ้าของในกรุงมะนิลา พร้อมจับกุมผู้ต้องหากว่า 450 คน โดยมีชาวไทยรวมอยู่ด้วย ตามรายงานระบุว่าศูนย์ปฏิบัติการแห่งนี้ตั้งอยู่ในย่านชานเมืองและทำเว็บไซต์หลอกคนให้มาเล่นพนันกีฬาออนไลน์กับลงทุน โดยมีเหยื่อส่วนใหญ่อยู่ในประเทศจีนและอินเดีย ทั้งนี้ เมื่อปีที่แล้ว ผู้นำฟิลิปปินส์ ได้ออกคำสั่งห้ามธุรกิจพนันออนไลน์ เนื่องจากอาจถูกกลุ่มอาชญากรรมใช้บังหน้าและประกอบกิจการผิดกฎหมาย แต่แม้จะมีคำสั่งออกมา ก็ยังคงมีชาวต่างชาติจำนวนมากแอบลักลอบทำธุรกิจผิดกฎหมายอยู่ โดยเฉพาะชาวจีน ข้อมูลจากคณะกรรมการต่อต้านองค์กรอาชญากรรมของประธานาธิบดีฟิลิปปินส์ เผยว่า ยังมีชาวจีนแอบทำธุรกิจหลอกลวงแบบนี้ในฟิลิปปินส์อยู่ประมาณ 21,000 คน

ในภาพรวมนั้น ผู้วิจัยได้เล็งเห็นว่า การเข้าใช้เว็บพนันนั้นนับเป็นปัญหาหนึ่งในวงการความปลอดภัยทางไซเบอร์ที่สามารถส่งผลกระทบต่อบุคคล และองค์กร ดังนั้น จึงถือว่ามีความจำเป็นอย่างยิ่งที่จะต้องดำเนินการออกแบบและพัฒนากระบวนการที่จะเป็นต้นแบบสำหรับการ ตรวจสอบว่า ระบบเว็บพนันแต่ละเว็บนั้น มีกลไกลการทำงานอย่างไร โดยกระบวนการและระบบต้นแบบนั้น หากสามารถเจาะระบบเว็บพนันเพื่อเปลี่ยนกลไกได้อย่างมีประสิทธิภาพแล้ว จะสามารถนำองค์ความรู้ที่ได้รับไปเผยแพร่ต่อ รวมถึงเพื่อเป็นการลดความสามารถในการดึงดูดผู้คนให้เสพติดการเข้าใช้เว็บพนัน

2.วัตถุประสงค์ของโครงงาน

2.1 เพื่อเพิ่มอัตราชนะ

2.2 เพื่อวิเคราะห์และทำความเข้าใจกลไกการทำงานของระบบเว็บพนัน

3.ขอบเขตของโครงงาน

3.1 การได้ทำการจำลองและวิเคราะห์กลไกของการทำงานของเว็บพนัน โดยการสร้างเว็บจำลองขึ้นจริง และทดสอบการทำงาน

3.2 การออกแบบและพัฒนากระบวนการจำลองสำหรับการตรวจสอบระบบเว็บพนัน

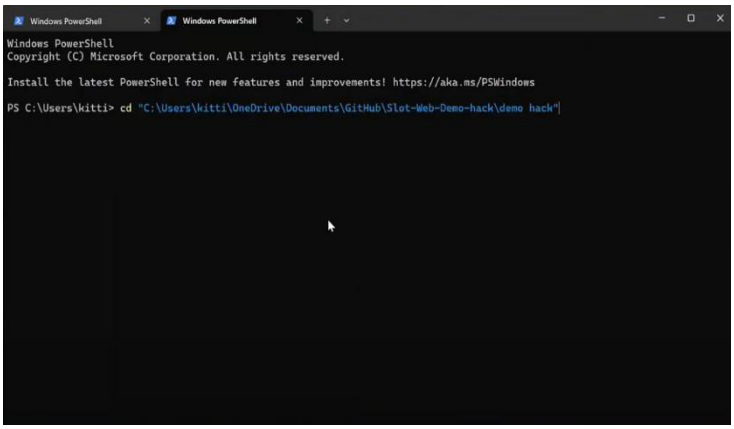
4.ผลการดำเนินงาน

4.1 ช่องโหว่ที่พบ

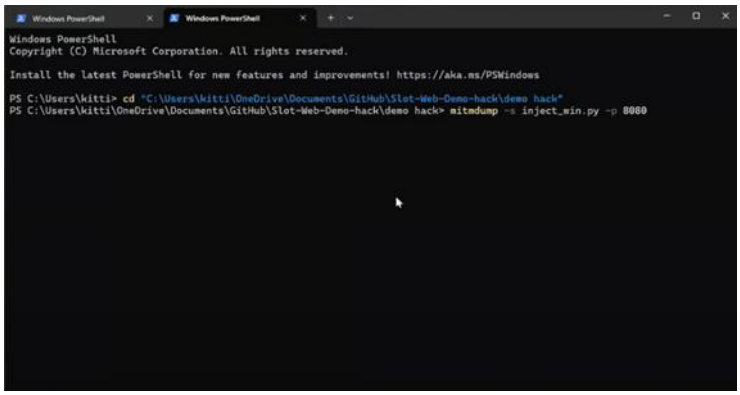
- SQL Injection (SQLi): ช่องโหว่ที่ผู้โจมตีสามารถแทรกคำสั่ง SQL เข้าไปในฟิลด์อินพุตเพื่อดึงข้อมูลหรือแก้ไขฐานข้อมูลได้

- Cross-Site Scripting (XSS): ช่องโหว่ที่ผู้โจมตีฝังสคริปต์ลงในเว็บ ทำให้โค้ดนั้นถูกดัดแปลงโดยผู้โจมตี
- Authentication Bypass: ช่องโหว่เหล่านี้มีสาเหตุจากการที่เว็บไม่มีการตรวจสอบข้อมูล หรือกรองข้อมูลที่ป้อนเข้ามา

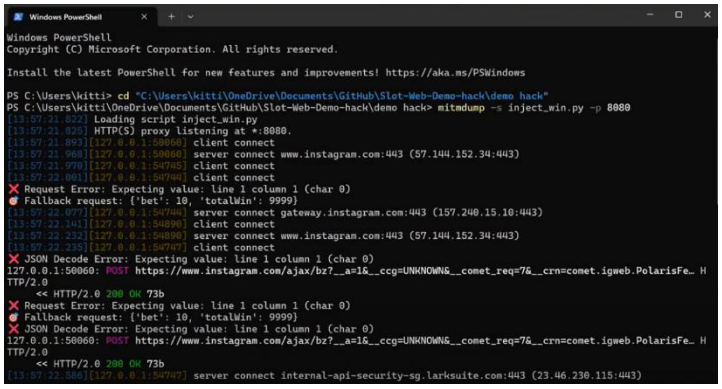
4.2 หน้าตาของช่องโหว่

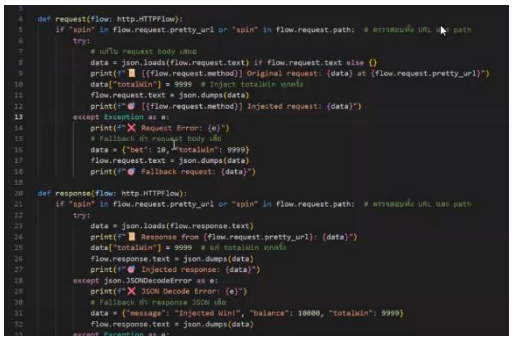


เชื่อมฐานข้อมูลของ Web Sever เข้ากับฐานข้อมูลของผู้โจมตี



เปลี่ยน Port ของ Web sever ให้กลายเป็น Port





นำ script ของผู้โจมตี เข้าไปแทนที่ script ของ Web sever เพื่อเปลี่ยนแปลงการรับส่งข้อมูล ระหว่าง หน้าบ้าน และ หลังบ้าน ของ web sever

4.3 รูปแบบการโจมตี

รูปแบบการโจมตีแบบนี้ เป็นการสาธิต “Client-side injection ผ่าน Man-in-the-Middle (MITM) proxy” โดยใช้ mitmproxy เพื่อแก้ไข request/response ขณะส่งข้อมูลระหว่าง frontend และ backend โดยอาศัยช่องโหว่ที่ backend ไม่ตรวจสอบค่าที่ client ส่งมา

โดยการโจมตีคือ เป็นเทคนิคที่ใช้ดักและแก้ไข คำขอ (Request) หรือ คำตอบ (Response) ที่ส่งระหว่าง client ↔ server โดยใช้เครื่องมือ MITM Proxy เช่น mitmproxy

ใช้วิธีนี้เพราะ ต้องการใช้ประโยชน์จากการหละกลวมของคนใน ในการรักษาข้อมูล เลยทำให้เข้าถึงฐานข้อมูลภายในได้

4.4 ข้อจำกัดการโจมตี

นำไปโจมตีในการโจมตีจริงไม่ได้เพราะ เราไม่รู้ และ ไม่สามารถติดต่อกับคนภายในองค์กรนั้นได้ เลยทำให้ไม่สามารถเข้าถึง Port ของ WebSever ได้ มีแต่คนภายในองค์กรเท่านั้นที่สามารถรู้ข้อมูลการโจมตีนี้ได้

หรือข้อมูลที่หลุดรั่วมาจากคนในองค์กรเท่านั้น

5.การป้องกันและการทดสอบ

5.1 การป้องกัน

ประเภทช่องโหว่	รายละเอียดช่องโหว่	แนวทางการป้องกัน
Client-side Injection	พบการแก้ไข request ผ่าน proxy เพื่อเข้าถึงข้อมูล	ทำให้ระบบserver-authoritative เมินtotalWinจากไคลเอนต์ทั้งหมด คิดผลสปินที่ฝั่งเซิร์ฟเวอร์เอง ตรวจอินพุตbet(ชนิด/ช่วง)และ เรียงลำดับบัญชี หักก่อน–จ่ายทีหลัง

Security Misconfiguration	การตั้งค่าระบบไม่รัดกุมเปิดช่องโจมตี	app.disable('x-powered-by') ซ่อนสแต็ก จำกัดขนาด payload
Unvalidated Input (Bet)	bet อาจเป็นชนิดผิด/ติดลบ/เกินขอบเขต ทำให้ยอดเงินเพี้ยน	ตรวจ bet ให้เป็นตัวเลขช่วง 1–1000 และเช็ค balanceพอก่อน ดำเนินการไม่ผ่านส่ง 400
Business-Logic / Accounting Error	เดิมใช้balance+=(totalWin - bet) พึ่งค่า totalWin ที่ถูกฉีด และอ่านยาก	เปลี่ยนเป็นลำดับบัญชีที่ถูกต้องหักbet ก่อน ถ้าชนะค่อย balance+=serverTotalWin (ค่า winที่เซิร์ฟเวอร์คำนวณเอง)

5.2 การทดสอบเวอร์ชันที่แก้ไขแล้ว

```
PROBLEMS    OUTPUT    DEBUG CONSOLE    TERMINAL    PORTS

> slot-web-demo-hack@1.0.0 start
> node server.js

✅ Server running at http://localhost:3001
Type Injection : number
[IGNORED] client-supplied totalWin = 12345
[SPIN] bet=100 injected=12345 server_total=328 balance=1228
```

เพิ่มการจำกัดขนาดbody เพื่อกัน payload ขนาดใหญ่

```
app.use(bodyParser.json({ limit: '10kb' }))
```

เปลี่ยนระบบการคำนวณจากฝั่งclient เป็นคำนวณบน server

```
app.post('/spin', (req, res) => {
  // รับมาเพื่อ log ได้ แต่ "ไม่ใช้คำนวณผล"
  const { bet, totalWin: injectedWin } = req.body || {}
  totalSpins++

  // เปิดดีบักผ่าน env หรือ header
  const debugMode = DEBUG_SPIN || req.get('X-Debug-Spin') === '1'

  // [NEW] ตรวจความถูกต้องของอินพุต
  if (typeof bet !== 'number' || !Number.isFinite(bet) || bet < 1 || bet > 1000) {
    return res.status(400).json({ error: 'invalid bet' })
  }
  if (balance < bet) {
    return res.status(400).json({ error: 'insufficient balance' })
  }

  // [NEW] log เพื่อพิสูจน์ว่าแม้จะมีการส่ง totalWin มา เราก็ "เมิน"
  if (typeof injectedWin !== 'undefined') {
    console.log('Type Injection :', typeof injectedWin)
    console.log('[IGNORED] client-supplied totalWin =', injectedWin)
  }
```

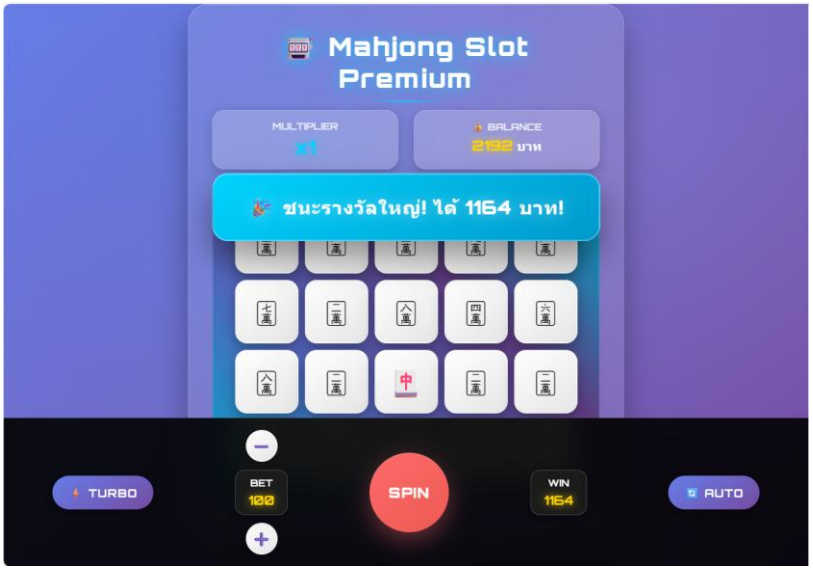
```
balance -= bet

let serverTotalWin = 0
let message = ''

const isWin = shouldWin()
if (isWin) {
  totalWins++
  // สุ่มผลรางวัล "ในเซิร์ฟเวอร์" เท่านั้น
  const baseScore = 100 + Math.floor(Math.random() * 500)
  const multiplier = [1, 2, 3, 5][Math.floor(Math.random() * 4)]
  serverTotalWin = baseScore * multiplier

  // จ่ายคืนตามผลที่ "เซิร์ฟเวอร์คำนวณ" เท่านั้น
  balance += serverTotalWin
  message = serverTotalWin >= 1000
    ? `🎉 ชนะรางวัลใหญ่! ได้ ${serverTotalWin} บาท!`
    : `🎉 ชนะ! รับไปเลย ${serverTotalWin} บาท`
} else {
  message = `😭 แพ้! เสีย ${bet} บาท`
}
```

5.3 เว็บที่มีการป้องกันแล้ว




```
Type Injection : number
[IGNORED] client-supplied totalWin = 12345
[SPIN] bet=100 injected=12345 server_total=328 balance=1228
Type Injection : number
[IGNORED] client-supplied totalWin = 0
[SPIN] bet=100 injected=0 server_total=0 balance=1128
Type Injection : number
[IGNORED] client-supplied totalWin = 0
[SPIN] bet=100 injected=0 server_total=1164 balance=2192
```

6.ผลลัพธ์ของโครงงาน

```
Type Injection : number
[IGNORED] client-supplied totalWin = 12345
[SPIN] bet=100 injected=12345 server_total=328 balance=1228
Type Injection : number
[IGNORED] client-supplied totalWin = 0
[SPIN] bet=100 injected=0 server_total=0 balance=1128
Type Injection : number
[IGNORED] client-supplied totalWin = 0
[SPIN] bet=100 injected=0 server_total=1164 balance=2192
```

เว็บไซต์ได้รับการป้องกันจากการโจมตีฝั่ง client side เพื่อเปลี่ยนค่า parameter ถึงแม้ว่าจะมีการ injected มาจากฝั่ง client

6.1 การแก้ไข

- **ตัดช่องโหว่แก้พารามิเตอร์ (Parameter Tampering)**
  - ลบการใช้ค่า totalWin จากไคลเอนต์ เปลี่ยนเป็นคำนวณผลสปิน **ฝั่งเซิร์ฟเวอร์เท่านั้น** (server-authoritative).
- **ตรวจอินพุตเข้มขึ้น (Input Validation)**
  - ตรวจ bet ต้องเป็นตัวเลขช่วง **1–1000** และเช็ค **balance พอก่อน** ดำเนินการ ถ้าอยู่นอกช่วงที่กำหนดจะ **HTTP 400**.
- **ลำดับบัญชีถูกต้อง (Safe Accounting Flow)**
  - เปลี่ยนจาก balance += (totalWin - bet) เป็น **หัก bet ก่อน** แล้วถ้าชนะค่อย balance += serverTotalWin.
- Security Misconfiguration
  - app.disable('x-powered-by') ซ่อนสแต็ก
  - จำกัดขนาด JSON: bodyParser.json({ limit: '10kb' }).

6.2 ผลลัพธ์หลังการแก้ไข

- หยุดการฉีดผลชนะได้จริงหลังจากย้ายไปคำนวณบน Server side
- ตรวจสอบง่าย ป้องกันการหักเงินที่ไม่ถูกต้อง
- กันอินพุตผิดปกติ ถ้ามีinputแปลกๆเข้ามาสามารถป้องกันไว้ก่อนได้
- ลดผิวโจมตีพื้นฐาน กันpayloadขนาดที่ใหญ่เกินกว่าปกติ เพื่อกันอะไรแปลกปลอม
- พิสูจน์ย้อนกลับได้ มี log และ dubug ชี้ชัดว่าถูกฉีดแต่ไม่เชื่อ

7.ประโยชน์ของโครงงาน

ต่อการป้องกัน/ลดแรงจูงใจให้คนเล่นพนัน

- เราโชว์ให้เห็นจริงว่า “ผลบนหน้าจอถูกบิดได้” ถ้าระบบทำมาผิดทาง คนดูงานจะเข้าใจทันทีว่าค่า “ชนะง่าย ๆ” ไม่น่าเชื่อถือ ⟶ ช่วยหักล้างภาพฝันว่า “เล่นแล้วรวย”
- มีภาพและตัวอย่างผลแบบก่อน–หลังให้เอาไปใช้สอน/รณรงค์ได้ ว่าทำไมต้องระวังเว็บพนัน และควรสงสัยกลไกที่โปร่งใสไม่พอ

ต่อทักษะและความเข้าใจด้านความปลอดภัย

- ได้เรียนครบวงจร: หาช่องโหว่ ,ทำ POC,โจมตีมออกแบบแพตช์,ทดสอบยืนยัน จนถึงเก็บหลักฐาน
- ได้แนวปฏิบัติที่นำไปใช้ซ้ำได้กับระบบที่เกี่ยวกับเงิน/แต้ม
    - ไม่พึ่งค่าจากฝั่งลูกข่ายในการคำนวณผล (server-authoritative)
    - ตรวจอินพุตให้เข้ม และจัดลำดับ “หักก่อน–จ่ายหลัง”
    - เสริม hardening เบื้องต้น และมีข้อมูลดีบักที่อ่านง่ายเวลาเกิดเหตุ
- เครื่องมือใช้ของจริง: mitmproxy/mitmdump, curl, การอ่าน/แกะ request-response อย่างเป็นระบบ

ต่อการนำไปต่อยอด

- พื้นฐานพร้อมสำหรับงานจริง: เพิ่ม helmet, rate-limit, CORS แบบ whitelist, ใช้ HTTPS/HSTS และลายเซ็นผลลัพธ์ (HMAC) ให้ฝั่งลูกค้าตรวจได้

โครงงานนี้ทั้ง “ลดความน่าเชื่อถือของเว็บพนันในสายตาผู้ใช้” และ “ยกระดับความเข้าใจเรื่องการอุดช่องโหว่” แบบลงมือทำจริง มีหลักฐานยืนยันชัดเจนว่า ก่อนแก้เจาะได้ 100% แต่หลังแก้เจาะไม่ติดเลย พร้อมแนวทางต่อยอดไปสู่ระบบที่ปลอดภัยขึ้นในโลกจริง.

ตารางเทียบ

หัวข้อเปรียบเทียบ	เดิม	แก้ไขแล้ว
หลักการบัญชี (Accounting Flow)	balance += (totalWin - bet) — totalWin มาจาก client (UI) และถูกนำมาคำนวณโดยตรง	balance -= bet; if (win) balance += serverTotalWin; — serverTotalWin คำนวณโดย server เท่านั้น
แหล่งที่มาของค่าผลชนะ (totalWin)	รับค่าจาก client ⟶ ไม่เชื่อถือ	คำนวณจาก server logic (ตัวอย่าง: RNG หรือ deterministic function + seed)
การตรวจสอบอินพุต (Input Validation)	ไม่มี/เบา — bet ไม่ถูกเช็คชนิดหรือขอบเขต	ตรวจ bet เป็นตัวเลข และค่าในช่วงที่ยอมรับ (1–1000) และเช็ค balance เพียงพอ

ลำดับธุรกรรม (Transaction Order)	คำนวณเพิ่ม/ลบพร้อมกัน (ไม่ชัดเจน)	หัก bet ก่อน แล้วคำนวณผลชนะและเพิ่มถ้าชนะ (หักก่อน–จ่ายหลัง)
การ hardening ของ HTTP/Server	X-Powered-By เปิดอยู่, ไม่มีจำกัด payload	app.disable("x-powered-by"), bodyParser.json({ limit: '10kb' })
การตรวจจับ/บันทึก (Logging / Audit)	บันทึกไม่เพียงพอ	บันทึกคำขอที่สำคัญ: bet, serverTotalWin, userId, txId, timestamp, client IP

การป้องกัน MITM / integrity	ไม่มีระบบตรวจสอบความถูกต้องของผลลัพธ์	ควรเสริม HMAC หรือ signature สำหรับผลลัพธ์ที่ส่งกลับ (optional) แต่หลักคือไม่พึ่งค่าจาก client
ผลกับ UX	ผลลัพธ์แสดงตามที่ client ส่ง ⟶ ดูเร็ว แต่ไม่ปลอดภัย	อาจมี latency เล็กน้อยจาก server-calculation แต่เชื่อถือได้